

SIZMA TESTİ RAPORU

Reflected XSS - Açılı Parantezler HTML Kodlu Senaryo

PortSwigger Web Security Academy Laboratuvarı

Hazırlayan: Şuheda EMLEK

Rapor Türü	Web Uygulama Güvenliği / Sızma Testi Raporu
Zafiyet Sınıfı	Reflected XSS
Etkilenen Bileşen	Blog arama fonksiyonu
İncelenen Bağlamlar	HTML attribute bağlamı ve JavaScript string bağlamı
Nihai Doğrulama	Alert çalışması ve lab solved durumu
Durum	Başarıyla doğrulandı

1.İçindekiler

1. Yönetici Özeti
2. Testin Amacı ve Kapsamı
3. Zafiyetin Teknik Tanımı
4. Kullanılan Payload ve Çözüm Mantığı
5. Adım Adım Test ve İstismar Süreci
6. Kanıt Ekran Görüntüleri ve Açıklamaları
7. Etki Analizi
8. Risk Değerlendirmesi
9. Düzeltme ve Önlem Önerileri
10. Sonuç

1. Yönetici Özeti

Bu rapor, PortSwigger Web Security Academy üzerinde yapılan reflected XSS testine ait bulguları belgelemektedir. Kullanıcı tarafından sağlanan ekran görüntülerinde, arama fonksiyonuna girilen değerin önce HTML attribute bağlamında yansıtıldığı gözlemlenmiş, daha sonra nihai olarak JavaScript string bağlamında başarıyla istismar edilen çözüm akışı doğrulanmıştır.

Test sırasında ilk olarak rastgele bir değer girilmiş ve sayfa kaynağı üzerinden girdinin hangi bağlamda kullanıldığı incelenmiştir. Ardından farklı payload denemeleri yapılmış, en sonunda ekran görüntülerinde alert penceresi ile kanıtlanan bir payload kullanılarak laboratuvar solved durumuna geçmiştir.

2. Testin Amacı ve Kapsamı

Çalışmanın amacı, blog arama fonksiyonunda kullanıcı girdisinin hangi bağlamda yansıtıldığını analiz etmek, güvenlik filtrelerini ve HTML encoding davranışını gözlemlemek ve kullanıcının tarayıcısında JavaScript çalıştırabilecek bir reflected XSS payload'ını doğrulamaktır.

Kapsam Unsuru	Acıklama
Hedef Sayfa	Blog arama sonuçları sayfası
Girdi Noktası	search parametresi
İnceleme Yöntemi	Tarayıcı üzerinde manuel test ve sayfa kaynağı analizi
Doğrulama Kriteri	alert penceresinin açılması ve lab solved durumu
Ek Gözlem	İlk prototipleme aşamasında attribute bağlamı ayrıca incelenmiştir

3. Zafiyetin Teknik Tanımı

Reflected XSS, kullanıcıdan alınan verinin yeterli filtreleme veya doğru bağlam kodlaması olmadan yanıt içeriğine geri yansıtılması sonucu ortaya çıkar. Bu tür senaryolarda aynı girdi farklı bağlamlarda kullanılabilir: bir HTML attribute içerisinde, bir JavaScript string'inde ya da dinamik olarak oluşturulan başka bir HTML parçası içinde.

Ekran görüntülerinde ilk inceleme adımları, girdinin input attribute değerinde ve document.write ile oluşturulan bir HTML parçasında kullanıldığını göstermektedir. Nihai çözüm ekranları ise arama teriminin bir JavaScript string bağlamında kullanıldığını ve o string'den çıkılarak alert fonksiyonunun çağrıldığını göstermektedir.

4. Kullanılan Payload ve Çözüm Mantığı

Aşama	Acıklama
Kesif	Rastgele bir alfanümerik değer girilerek yansımanın davranışı gözlemlendi.
Kaynak Analizi	Sayfa kaynağı açılarak search değerinin HTML ve script bağlamındaki kullanımı doğrulandı.
Prototip Deneme	Attribute bağlamı için "onmouseover="alert(1) benzeri denemeler yapıldı.
Nihai Payload	Başarılı ekran görüntüsünde URL içinde %27-alert%281%29-%27 formunda görülen payload ile string kapanarak alert tetiklendi.
Sonuc	Alert penceresi açıldı ve laboratuvar solved durumuna geçti.

5. Adım Adım Test ve İstismar Süreci

Adım 1 - Hedef laboratuvar sayfasının açılması

Başlangıçta laboratuvar sayfası açılmış ve arama alanına rastgele bir değer girilmiştir. Bu aşamada lab durumunun Not solved olduğu doğrulanmıştır.

Adım 2 - Yansımanın kullanıcı arayüzünde gözlemlenmesi

Arama yapıldıktan sonra sonuç sayfası incelenmiş ve girilen değer hem sonuç başlığında hem de arama kutusu içindeki value alanında yansıtıldığı görülmüştür.

Adım 3 - Sayfa kaynağı ile bağlam tespiti

Sağ tık / sayfa kaynağını görüntüle adımı ile HTML yapısı incelenmiş, search değerinin input attribute içinde ve document.write ile oluşturulan bir img src parçası içinde kullanıldığı kayıt altına alınmıştır.

Adım 4 - Prototip payload denemeleri

Attribute bağlamından çıkmak için farklı payload denemeleri uygulanmıştır. Ekran görüntülerinde onmouseover özelliği eklemeye yönelik bir deneme bulunduğu gözlenmiştir.

Adım 5 - Nihai çözüm akışının tespiti

İlerleyen ekran görüntülerinde çözümün JavaScript string bağlamında elde edildiği, sayfa kaynağında searchTerms değişkeninin script içinde tanımlandığı ve bunun document.write ile kullanıldığı görülmüştür.

Adım 6 - Başarılı payload'ın uygulanması

Son URL ekranında search parametresine uygulanan payload sonrasında alert penceresi açılmış, hemen ardından başarı bandı ve solved durumu görüntülenmiştir.

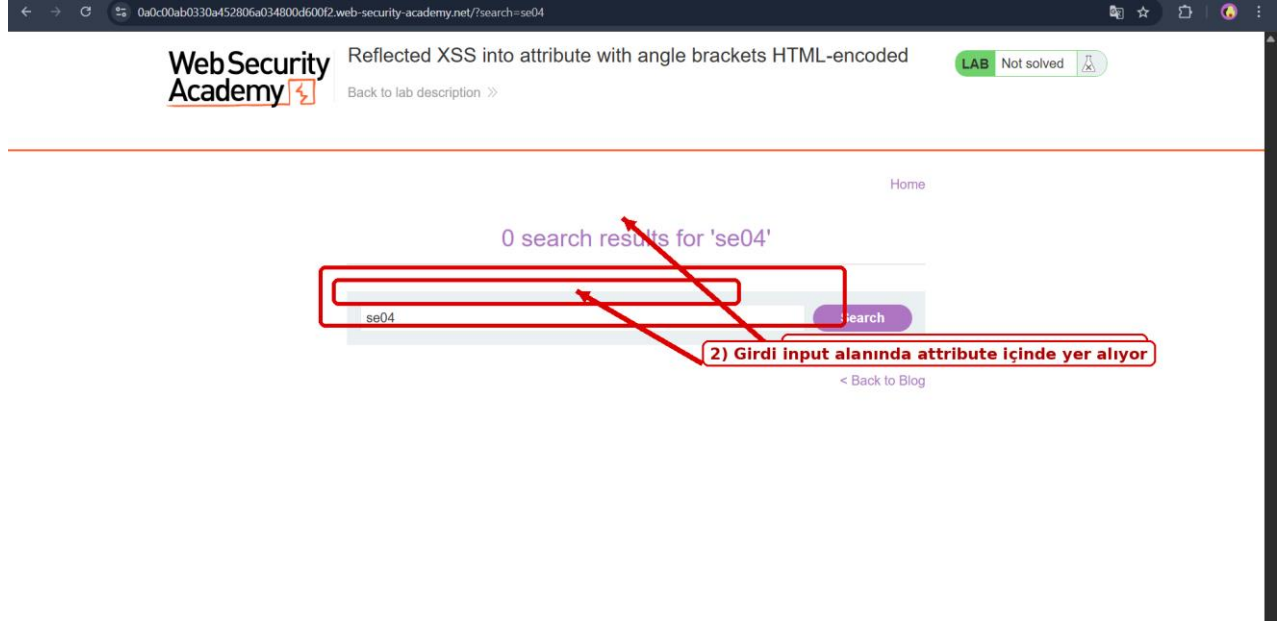
6. Kanıt Ekran Görüntüleri ve Açıklamaları

Şekil 1 - İlk keşif ekranı



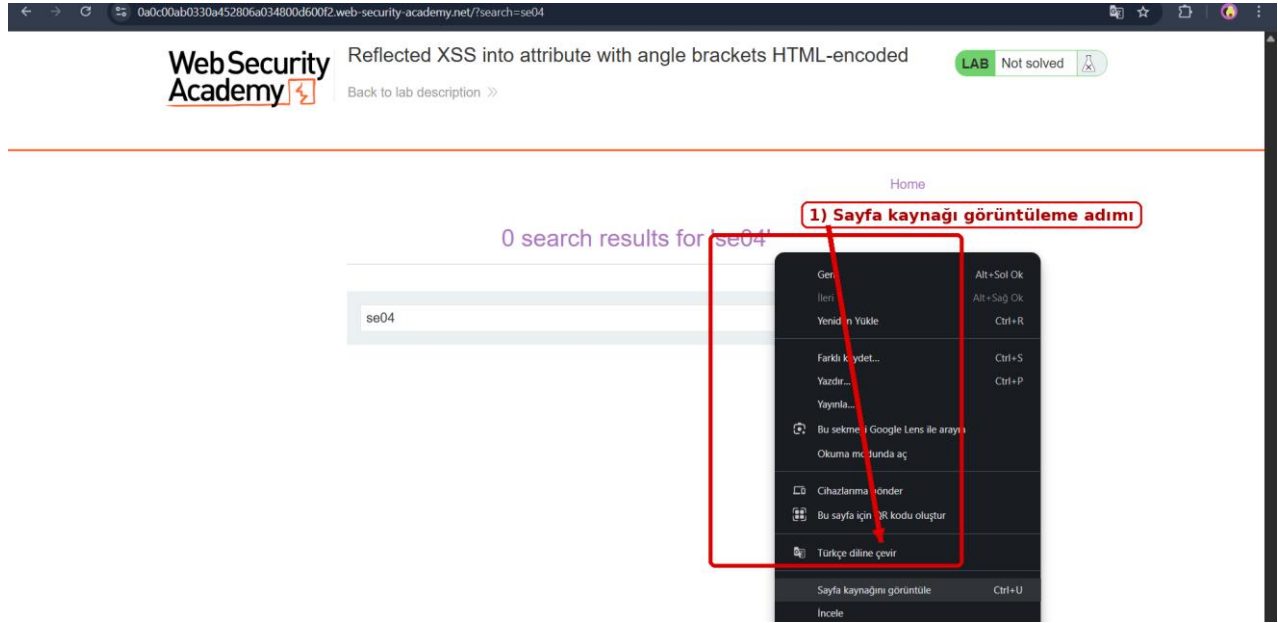
Açıklama: Başlangıç sayfasında laboratuvar başlığı, Not solved durumu ve arama kutusuna girilen ilk test değeri gösterilmektedir.

Şekil 2 - Yansıyan sonuç sayfası



Açıklama: Girilen değerin sonuç başlığında ve input value alanında yansıtıldığı görülmektedir.

Şekil 3 - Sayfa kaynağını açma adımı



Açıklama: Sağ tık menüsü üzerinden HTML kaynağını inceleme aşaması kayda alınmıştır.

Şekil 4 - HTML kaynak kodunda ilk bağlam analizi

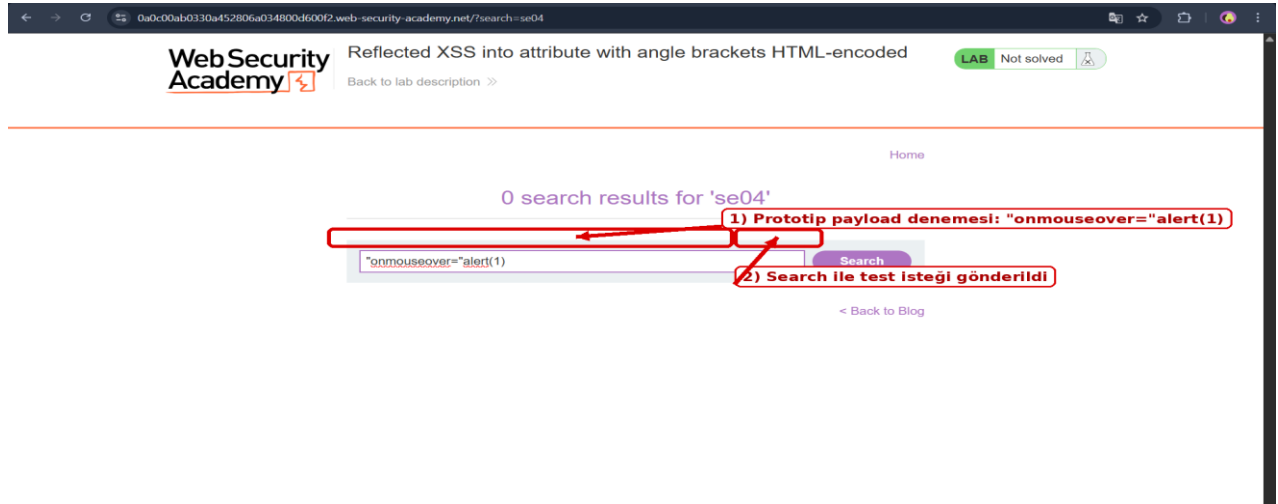
```
25 </p>
26 </svg>
27 </a>
28 </div>
29 <div class="widgetcontainer-lab-status is-notsolved">
30 <span>LAB</span>
31 <p>Not solved</p>
32 <span class="lab-status-icon"></span>
33 </div>
34 </div>
35 </div>
36 </section>
37 </div>
38 <!-- HEAD: END -->
39 <div theme="blog">
40 <section class="maincontainer">
41 <div class="container is-page">
42 <header class="navigation-header">
43 <section class="top-links">
44 <a href="/>Home</a><p></p>
45 </section>
46 </header>
47 <header class="notification-header">
48 </header>
49 <section class="blog-header">
50 <h1>0 search results for 'se04'</h1>
51 <hr>
52 <section>
53 <form action="/ method=GET">
54 <input type="text" placeholder="Search the blog..." name="search" value="se04">
55 </form>
56 </section>
57 <section class="blog-list no-results">
58 <div class="is-linkback">
59 <a href="/>Back to Blog</a>
60 </div>
61 </section>
62 </div>
63 </div>
64 </div>
65 </div>
66 <div class="footer-wrapper">
67 </div>
68 </div>
69 </body>
70 </html>
```

1) search değeri HTML içinde görülüyor

2) document.write ile attribute oluşturulduğu doğrulandı

Açıklama: Search değerinin HTML içerisinde ve document.write ile oluşturulan img src parçası içinde kullanıldığı doğrulanmıştır.

Şekil 5 - Attribute prototip payload denemesi



Açıklama: Arama kutusuna attribute eklemeyi hedefleyen bir payload girilmiş ve Search butonu ile test gönderilmiştir.

Şekil 6 - Nihai çözümün uygulandığı laboratuvar kaynak kodu

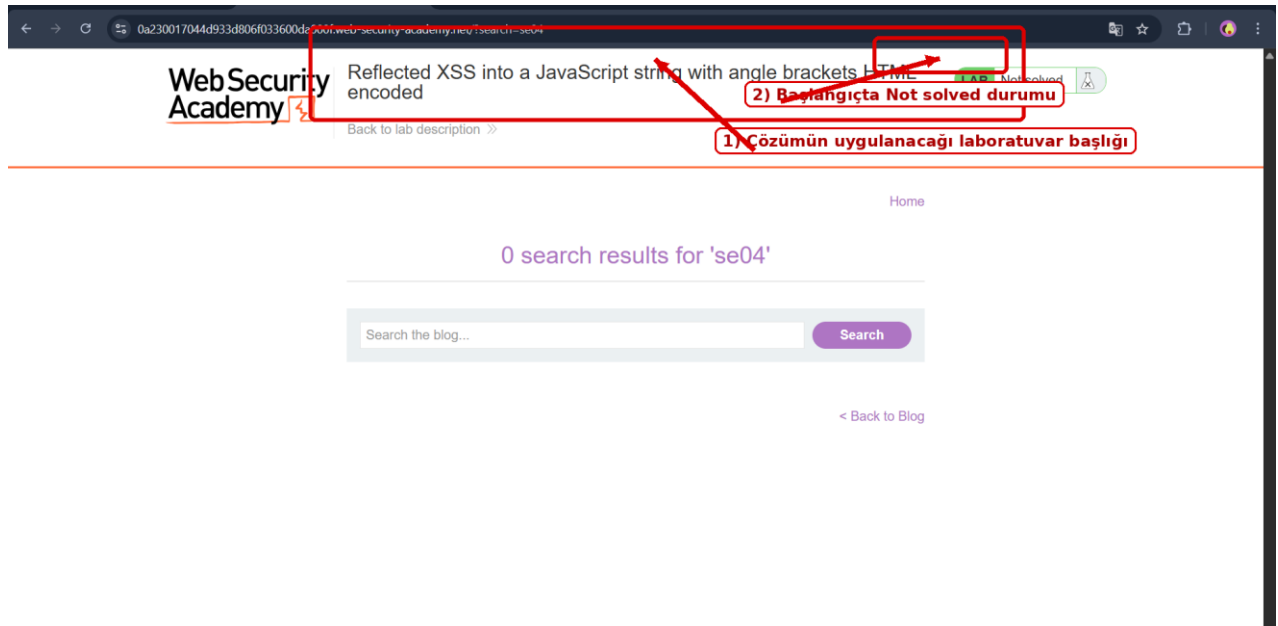
```
26 </svg>
27 </div>
28 <div class="widgetcontainer-lab-status is-notsolved">
29 <span>LAB</span>
30 <p>Not solved</p>
31 <span class="lab-status-icon"></span>
32 </div>
33 </div>
34 </div>
35 </div>
36 </div>
37 <!-- LAB_HEADER_END -->
38 <div theme="blog">
39 <section class="maincontainer">
40 <div class="container is-page">
41 <header class="navigation-header">
42 <section class="top-links">
43 <a href="/>Home</a><p></p>
44 </section>
45 </header>
46 <header class="notification-header">
47 </header>
48 <section class="blog-header">
49 <h1>0 search results for 'se04'</h1>
50 <div>
51 </div>
52 </section>
53 <section class="search">
54 <form action="/" method="GET">
55 <input type="text" placeholder="Search the blog..." name="search">
56 <button type="button" value="Search">Search</button>
57 </form>
58 </section>
59 <script>
60 var searchTerms = 'se04';
61 document.write('');
62 </script>
63 <section class="blog-list no-results">
64 <div class="is-linkback">
65 <a href="/>Back to Blog</a>
66 </div>
67 </section>
68 </div>
69 </section>
70 <div class="footer-wrapper">
71 </div>
72 </div>
```

1) Nihai çözülen laboratuvar sayfa kaynağı

2) searchTerms JavaScript string içinde tutuluyor

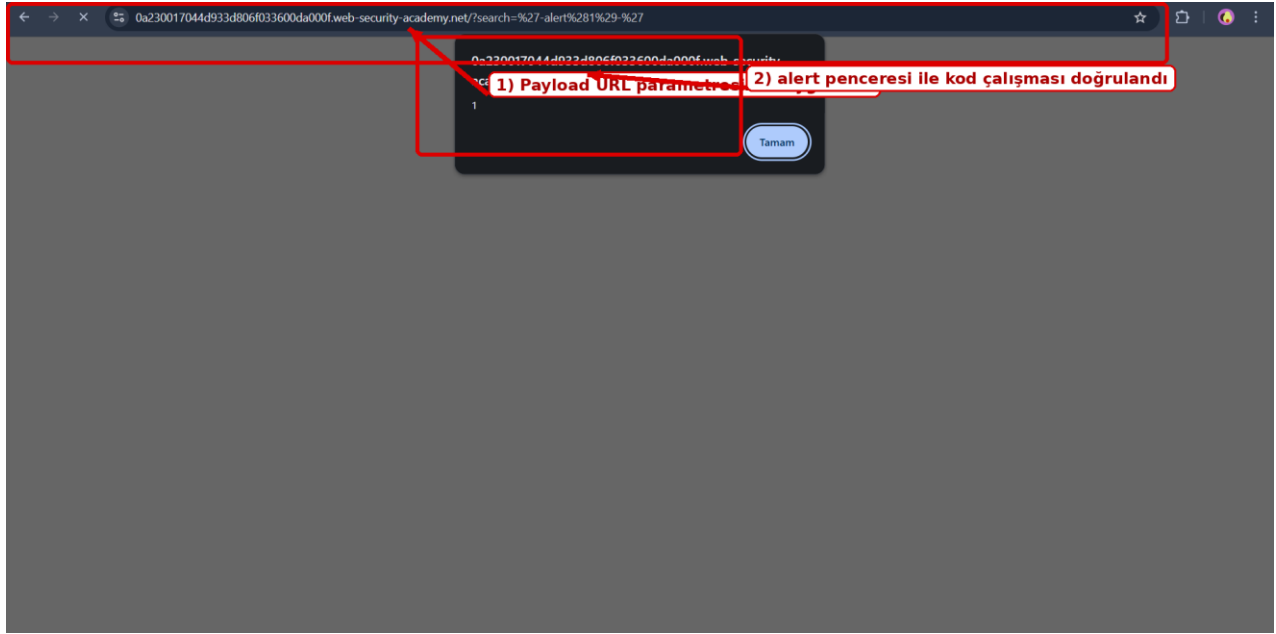
Açıklama: Ekran görüntüsünde searchTerms değişkeni script içinde tutulmakta ve document.write ile kullanılmaktadır. Bu, JavaScript string bağlamını göstermektedir.

Şekil 7 - JavaScript string bağlamındaki hedef sayfa



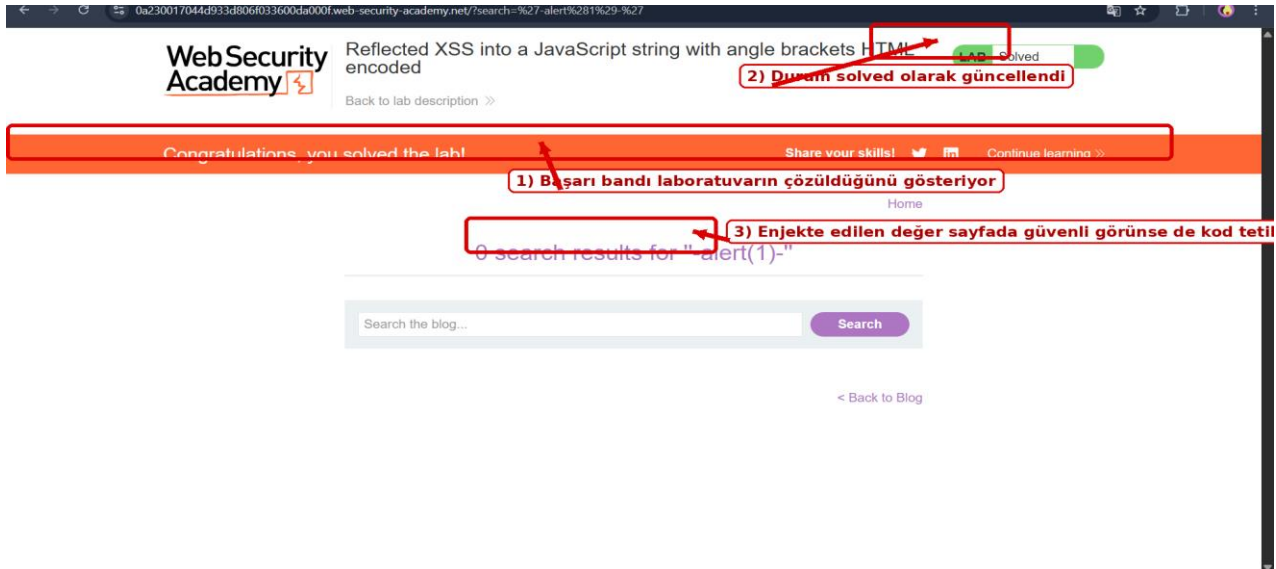
Açıklama: Çözümün uygulanacağı laboratuvar sayfası ve Not solved durumu gösterilmektedir.

Şekil 8 - Alert penceresi ile başarılı istismar



Açıklama: URL içindeki payload uygulandıktan sonra alert penceresi açılmış ve kod yürütme doğrulanmıştır.

Şekil 9 - Başarı ve solved ekranı



Açıklama: Laboratuvarın başarıyla çözüldüğünü gösteren turuncu başarı bandı ve solved durumu görülmektedir.

7. Etki Analizi

Gerçek bir uygulamada bu tip bir reflected XSS zafiyeti, kullanıcının özel hazırlanmış bir URL'yi ziyaret etmesi ile tetiklenebilir. Saldırganın amacı; kullanıcının tarayıcısında keyfi JavaScript çalıştırmak, oturum bağlantılı bilgileri etkilemek veya sayfa içeriğini manipüle etmektir.

- Kurban tarayıcısında keyfi JavaScript çalıştırılması
- Kullanıcı arayüzünün manipüle edilmesi ve sahte içerik gösterilmesi
- Oturum ve istemci tarafı verilerinin risk altına girmesi
- Güvenilir bir uygulama alan adının saldırı vektörü olarak kullanılması

8. Risk Değerlendirmesi

Kriter	Değerlendirme
Zafiyet Türü	Reflected XSS
Sömürülebilirlik	Yüksek
Teknik Karmaşıklık	Düşük - Orta
Kullanıcı Etkisi	Yüksek
Genel Risk Seviyesi	Yüksek

9. Düzeltme ve Önlem Önerileri

- Kullanıcı girdisi kullanıldığı bağlama uygun şekilde encode edilmelidir.
- JavaScript string içinde kullanılan değişkenler için karakter kaçışlama ve güvenli veri yerleştirme yöntemleri uygulanmalıdır.
- document.write gibi riskli API kullanımı kaldırılmalı veya güvenli DOM API'leri ile değiştirilmelidir.
- HTML attribute ve script bağlamları için ayrı güvenlik kontrolleri uygulanmalıdır.
- Reflected XSS testleri, arama ve filtreleme gibi tüm girdi alanları için düzenli olarak tekrar edilmelidir.

10. Sonuç

Yapılan test ve görsel kanıtlar, arama fonksiyonunun reflected XSS riskine açık olduğunu göstermektedir. İlk aşamada attribute bağlamına yönelik prototipleme yapılmış, daha sonra JavaScript string bağlamında başarılı payload ile alert fonksiyonu çağrılarak laboratuvar solved durumuna geçmiştir. Bu durum, uygulamanın güvenilmeyen girdiyi farklı bağlamlarda güvenli şekilde işleyemediğini ve istemci tarafında kod çalıştırılmasına izin verebildiğini ortaya koymaktadır.